WHITEPAPER NO. 2

Trenches and Drones

Network Defense for a War of Attrition

Practical, Integrated Steps for Mid-Size Organizations

Whitepaper No. 2

NOVEMBER 2026

William Aaron Turner, Founder & President

Infinitum Corporation, Washington, DC

Trenches and Drones: Network Defense for a War of Attrition
Practical, Integrated Steps for Mid-Size Organizations

Infinitum Corporation Whitepaper No. 2 · November 2026 · **Released November 2, 2026**

Neutrality statement. This paper draws general lessons about technology and conflict from public sources. It takes no side and makes no claim about any party.

© 2026 Infinitum Corporation. All rights reserved. No part of this publication may be reproduced or distributed without written permission, except for brief quotations with attribution.

DISCLAIMER

This whitepaper is provided for general information only. It is not legal, regulatory or professional advice for any specific situation, and it does not create a client relationship. Statistics are taken from the public sources cited and remain the property of their publishers; they describe the samples studied by those publishers and are not benchmarks or predictions for any particular organization. Infinitum Corporation makes no promise or guarantee about the security outcome any organization will achieve.

This paper is strictly analytical and defensive. References to irregular warfare, gray-zone competition and hybrid threats are used as an analytic lens for defense and resilience. Nothing in this paper is instruction for offensive activity. Any security testing referred to here means authorized, scoped testing performed with the written permission of the system owner.

Scenarios in Part VIII are illustrative and hypothetical. They do not describe any real organization, client or incident.

Trademarks and framework names belong to their respective owners. Citation of a source does not imply that its publisher endorses this paper or Infinitum Corporation.

CONTACT

Infinitum Corporation, Washington, DC · 1629 K Street NW, Suite 300
https://www.theinfinitumcorporation.com
info@theinfinitumcorporation.com
Telegram: https://t.me/infinitumcorporation · X: https://x.com/infinitumceo

All data comes from the public record. All conclusions are mine. — W.A.T.

Contents

Executive summary 4

The problem: they do not need to beat you once 7

The modern battlefield, read by a security analyst 10

Analysis: five fronts and two cross-cutting concerns 13

Part I: Trenches. Depth beats a hard shell 13

Part II: Drones. Cheap mass against your attention 16

Part III: Electronic warfare. When the signal lies 19

Part IV: Sensors. Assume you are being watched 23

Part V: Supply lines. The rear is part of the front 26

Part VI: Command. Decide faster than the grind 29

Part VII: People. Endurance is the strategy 32

Part VIII: Three scenarios 34

Recommendations 38

Conclusion 44

About Infinitum Corporation 45

References 46

Glossary 48

Executive summary

By William Aaron Turner, Founder and President, Infinitum Corporation.

Nobody wins this fight in a day.

That is the first thing to understand about defending a network. The contest is not one big battle. It is a long grind of small, cheap, constant pressure. Scans that never stop. Phishing waves that arrive in bursts. Floods of junk traffic that last nine minutes and come back tomorrow. A device at the edge of your network that has been waiting for a patch for six weeks.

Attrition is the right word for it. Attrition means wearing the other side down. It is a contest of cost, endurance and replacement. The side that can absorb losses, repair, adapt and keep operating outlasts the side that cannot.

This paper is about how a mid-size organization stays in that contest. It is a practical look at network defense when the pressure is persistent, automated and cheap for the people applying it.

I read security problems through one lens: irregular warfare. That is the study of how states and other groups compete through indirect, non-attributable or asymmetric means, and how to counter them. Joint doctrine says irregular warfare "seeks to create dilemmas and increase risk and costs to adversaries" (JP 1 Vol 1, 2023, as quoted in U.S. Army CALL, 2025). You don't need to care about doctrine to benefit from it. You only need to notice that the people working against your network behave the way it describes.

Then add the picture public analysts paint of the modern battlefield. My shorthand for it: trench-style grind fused with science fiction. Defense in depth and dug-in positions. Cheap drones in huge numbers. Jammed and spoofed signals. Sensors everywhere. Supply lines under constant observation (CSIS, 2025a; CSIS, 2025b; CSIS, 2025c).

That is a comparison, not a claim that your network is a front line. Nobody is shooting at your servers. **This paper draws general lessons about technology and conflict from public sources. It takes no side and makes no claim about any party.** It leaves out casualty, loss and performance figures for every side, because they are contested and because a security team does not need them. The lessons sit at the level of technology and phenomena, and each one comes back to a decision you can make on Monday.

Five fronts, one war

The paper walks through five fronts. Each pairs a feature of the modern battlefield, as public sources describe it, with the same feature on your network.

- **Trenches: depth.** CSIS says defenders who can dig in with effective counter-drone measures hold a significant advantage over those who must cross open land (CSIS, 2025a). On a network, that means segmentation, identity checks at every line, and an implicit trust zone kept "as small as possible" (NIST SP 800-207, 2020).
- **Drones: cheap mass.** CSIS puts the economics in one line: "If a $500 drone can destroy a multimillion-dollar tank, so, too, can a USV swarm destroy a fleet of ships" (CSIS, 2025a). Your version is automated scanning, credential stuffing and flood traffic. In Verizon's data, the median breached entity facing distributed denial of service (DDoS) contended with 17 distinct attacks over a year, and half of all attacks lasted less than nine minutes (Verizon, 2026).
- **Electronic warfare: trust under attack.** Jamming and spoofing target the signals that machines trust. IATA data, cited in a joint release with the European aviation regulator EASA, shows GPS signal loss events up 220% between 2021 and 2024 (EASA and IATA, 2025). Your network has signals too: time sources, name resolution, identities, voices on the phone. NIST lists logging software and certificate management among the things that depend on synchronized time (NIST IR 8323r1, 2023).
- **Sensors: you are watched.** CSIS says forces "must assume that they will be seen and their movements and emissions detected" (CSIS, 2025b). Assume the same about your internet-facing surface. Edge devices act as boundaries, and unsecured, they make it easier for "even unskilled malicious cyber actors" (NSA, 2025).
- **Supply lines: the rear is not safe.** CSIS warns that logistics chains "will be in constant peril" (CSIS, 2025a). IBM found supply chain compromise was the second most common initial attack vector in breaches it studied, and that those breaches took 258 days on average to identify and contain (IBM and Ponemon Institute, 2026).

What the evidence says

Three findings stand out.

First, the pressure is constant, and mostly cheap. ENISA analyzed 4,875 incidents in the EU over a twelve-month period. DDoS made up 77% of reported incidents. Only 2% of the hacktivism incidents, which were primarily low-impact DDoS, resulted in service disruption (ENISA, 2025). Cheap does not mean harmless, and it does not mean pointless. It means the attacker is spending your attention.

Second, the real damage comes from gaps that stay open. Verizon found only 26% of known-exploited vulnerabilities in its dataset were fully remediated, down from 38% the year before, and the median time to fully patch rose to 43 days from 32 (Verizon, 2026). In its analysis of small and medium-sized businesses, Verizon says many ransomware attacks are opportunistic, and victims were hit because

they had compromised credentials (38%) or unpatched vulnerabilities in edge devices (29%) (Verizon, 2026).

Third, endurance is a cost. IBM reports the global average cost of a data breach reached a record USD 4.99 million, and the mean time to identify and contain a breach rose to 247 days. Breaches with life-cycles longer than 200 days cost more on average than shorter ones (USD 5.65 million against USD 4.32 million) (IBM and Ponemon Institute, 2026). Every day an intruder spends inside your lines is a day you pay for.

What to do

The recommendations come in seven moves, built to be sequenced by a team of a few people.

1. **Map the ground.** Inventory your edge, your crown assets and your dependencies. You cannot defend what you cannot see.
2. **Dig in.** Build depth: segmentation, per-session access, phishing-resistant authentication, and a small implicit trust zone.
3. **Close the cheap doors.** Patch known-exploited vulnerabilities on the edge first. Put DDoS protection and automation where the volume is.
4. **Keep a second source.** Verify out of band. Run more than one trusted time source. Test what happens when the primary fails.
5. **Reduce your signature.** Shrink what the internet can see. Build your own sensors. Place decoys with legal sign-off.
6. **Plan for the rear to burn.** Map suppliers and platforms. Keep offline copies and manual fallbacks that you have actually rehearsed.
7. **Decentralize the decisions.** Write down who may act without asking. Keep a comms channel that does not depend on the network you are defending. Share lessons within hours, not months.

None of these moves needs a miracle product. All of them need a campaign mindset: staffing for year two, measuring against your own baseline, and testing the plan until the plan breaks in a rehearsal instead of a real incident.

This paper includes a 30/60/90-day plan, a 12-month roadmap, a 30-item self-assessment, and three illustrative scenarios that are hypothetical and say so.

Every figure in this paper belongs to the source cited. I make no claim about the results any organization will achieve. Don’t take my word for it. Read the sources, then decide.

The problem: they do not need to beat you once

Here is the uncomfortable math.

An attacker sends ten thousand messages. One person clicks. An attacker scans a million addresses. One appliance is a year behind on patches. An attacker floods a website for nine minutes, then does it again at lunch. None of that costs much. All of it costs you something.

IBM states the imbalance in a sentence: attacks "can be launched for thousands while breaches cost millions" (IBM and Ponemon Institute, 2026). That is the whole problem in a line. The attacker's cost per attempt is low and falling. Your cost per defended attempt is not.

That is attrition. Not a single decisive blow. A steady drain on attention, people, money and nerve, until something gives.

What the evidence shows

I will keep this section to numbers I can trace to a source I opened. Every figure below belongs to the publisher named.

Most of the pressure is volume. ENISA analyzed 4,875 incidents across the European Union between July 2024 and June 2025. DDoS was the dominant incident type, 77% of reported incidents, mostly from hacktivists. Hacktivism represented almost 80% of all incidents, primarily low-impact DDoS campaigns, and only 2% of hacktivism incidents resulted in service disruption (ENISA, 2025).

Read that twice. Almost all of it was noise. Almost none of it broke anything. And ENISA still names ransomware as the most impactful threat in the EU (ENISA, 2025). The loud thing and the dangerous thing are not the same thing, and the loud thing is designed to make you forget it.

The volume is real, and it comes in bursts. Verizon's 2026 Data Breach Investigations Report (DBIR) recorded 5,514 denial-of-service incidents. The median attack size has fluctuated between 4.2 and 6 Gbps over recent years, and 50% of attacks lasted less than nine minutes. The largest attacks grew 198% in bits per second and 156% in packets per second compared with the prior year (Verizon, 2026).

Verizon also looked at how often organizations get hit. In a sample of 217 victim organizations, 2% saw periodic, predictable attacks, 40% saw bursts of activity, and 57% saw attacks at seemingly random intervals. The "bursty" victims faced a median of about 17 different attacks over the year, with about one day between attacks. Half of them faced at least 10 different attack types (Verizon, 2026).

Picture the load. Seventeen separate hits, many types, a day apart. That is not an event. It is a posture.

The way in is usually old and cheap. ENISA found phishing was the leading intrusion route at about 60%, followed by vulnerability exploitation at 21.3% (ENISA, 2025). Verizon found exploitation of vulnerabilities is now the most prominent initial access vector in its dataset at 31%, up from 20% the year before (Verizon, 2026).

And the vulnerabilities stay open. Verizon reports that only 26% of the vulnerabilities in the CISA Known Exploited Vulnerabilities (KEV) catalog found in its partners' scans were fully remediated, a drop from 38% a year earlier. The median time to fully patch rose to 43 days from 32. The median number of KEV vulnerabilities an organization had to patch in a year rose to 16 from 11 (Verizon, 2026).

The small and mid-size get hit too. Verizon found about 96% of ransomware victims, among cases where organization size was known, were small and medium-sized businesses. In its SMB analysis, it describes many of these attacks as opportunistic: victims were chosen because they had compromised credentials (38%) or unpatched vulnerabilities in edge devices (29%) (Verizon, 2026).

The pain lasts. IBM puts the global average cost of a breach at a record USD 4.99 million, and the mean time to identify and contain at 247 days. Ransomware showed up in 39% of breached organizations in its sample, up from 34%. The most common tactic shifted: threatening brand reputation was cited by 41% of those hit by ransomware, ahead of encryption at 23% (IBM and Ponemon Institute, 2026).

Pressure on your trust and your public standing, not only on your files.

And AI is turning the dial. ENISA reports that AI-supported phishing campaigns reportedly represented more than 80% of observed social engineering activity worldwide by early 2025 (ENISA, 2025). IBM reports more than one in four organizations that experienced a malicious attack said it was AI-driven (IBM and Ponemon Institute, 2026). Verizon reports roughly 15% of non-malicious bot traffic in the third quarter of 2025 was AI bots, and describes security teams scrambling to automate the handling of AI scanning bots and AI-driven traffic (Verizon, 2026).

The three drains

Attrition drains three things. Name them, because each one needs its own defense.

Attention. Every alert, every flood, every phishing report pulls a person's eyes. Attention is finite. Attackers know it. Volume is a way of buying it.

People. ISC2's 2024 workforce study found 67% of respondents reported a staffing shortage, and 90% reported one or more skills gaps (ISC2, 2024). Tired people miss things. People who quit take the map with them.

Money. Budgets are annual. Campaigns are not. A program built to survive one audit cycle will not survive three years of steady pressure.

Four ways a mid-size organization loses

I see four failure modes. This is my analysis. It is not a measured result.

1. **Exhaustion.** The team is so busy with the volume that nobody has time for the slow, important things: patching the edge, testing backups, writing the plan.
2. **Blind spots.** You cannot see the whole position. A forgotten appliance. A supplier connection nobody mapped. An old account.
3. **Single points of failure.** One identity provider, one firewall pair, one clock, one administrator who knows how it works. When it goes, everything goes.
4. **Slow adaptation.** The adversary changes a technique in weeks. Your annual policy review does not.

Hold those four in your head. The rest of this paper is a response to them.

What this paper is, and is not

It is a defensive, practical guide for security and IT leaders in mid-size organizations. It uses the modern battlefield as a lens, and every lesson ends in something you can do.

It is not a weapons paper. It does not describe how to build, buy, aim or defeat any weapon. It contains no targeting content and no training content. When it speaks of testing, it means authorized, scoped testing of your own systems, performed with written permission. It does not recommend striking back at anyone. Responses to attackers belong to law enforcement and to people with authority and evidence.

It is not a vendor list. It makes no promise that any product, or any plan in this paper, will produce a particular result for you.

The modern battlefield, read by a security analyst

Let me be plain about what I am doing here, and what I am not.

I am reading public analysis of modern conflict for general lessons about technology. I am not assessing any government, army or leader. I make no claim about any party. This paper draws general lessons about technology and conflict from public sources. It takes no side and makes no claim about any party.

I leave out casualty, loss and performance figures for every side. They are contested. They are estimates. And they are not what a security team needs to make a decision. I also leave out the attribution that some sources attach to specific events. That is not because it does not matter. It is because I am not the right author to judge it, and the lesson does not depend on it.

What I keep are the phenomena. Drone saturation. Jamming and spoofing. Sensor transparency. Cheap mass. Logistics under observation. Decentralized decisions.

The framing

My shorthand: trench-style grind fused with science fiction.

Think of the first world war's long stalemate, the lines of dug-in positions where nothing moved fast. Now add cheap drones overhead, signals jammed and spoofed, satellites and commercial sensors watching the ground, and a cycle of measure and countermeasure that turns over in weeks.

CSIS opens its chapter on technological evolution with the point that new technology drives tactics in unprecedented ways, and that "the party that innovates, procures, and adapts first secures an often insurmountable edge." It gives an example from the first world war: the development of the first rudimentary tank to break the stalemate of trench warfare (CSIS, 2025a).

It then offers the line I keep coming back to: "the next generation of warfare will not be defined solely by who possesses the most advanced technology, but by who can integrate, adapt, and counter it the fastest" (CSIS, 2025a).

Integrate. Adapt. Counter. That is a good description of a security program.

What public analysis describes

Here are the features I draw on, with the source for each.

Cheap, flexible sensing and strike. CSIS says the most marked change has been cheap, flexible and highly maneuverable intelligence, surveillance and reconnaissance (ISR) drones. It says cover and

concealment are "of the utmost importance," and that large, highly visible formations are more vulnerable to drone strikes (CSIS, 2025a).

A cat-and-mouse cycle. CSIS describes "a highly iterative game of cat and mouse, with advancements in electronic warfare meeting drone advancements step for step" (CSIS, 2025a). It quotes an analyst describing a "six week learning cycle on the battlefield" (CSIS, 2025a).

Electronic warfare as the norm. In its chapter on space, CSIS calls the pervasiveness of electronic warfare (EW) "one of the most dominant features of the modern battlefield." It describes EW as a "temporary and reversible way" to target satellite navigation, communications signals and ISR collection, and says "going forward, EW will be the norm" (CSIS, 2025b). It also warns that regions outside conflict zones will experience greater electromagnetic interference, risking harm to civil and commercial transportation and public safety (CSIS, 2025b).

Transparency. CSIS says commercial space capabilities have introduced "a new level of transparency" and that "all militaries must adapt to a world where movements, emissions, and signatures are constantly monitored" (CSIS, 2025b). A separate CSIS chapter on intelligence says wars of the future will be fought "in conditions of near transparency," and that "information is cheap. Processing it is expensive, and sense-making is exquisite" (CSIS, 2025c).

Logistics under pressure. CSIS says logistics chains "will be in constant peril" and that modern armies "need to anticipate that only a fraction of supplies will get through" (CSIS, 2025a).

Decentralized units. CSIS says the future is shifting toward "smaller, highly mobile, adaptable units, where field commanders are empowered to make decisions" while minimizing their communications signature (CSIS, 2025a).

No clean front line. CSIS warns that as commercial providers take on greater roles in military operations, the line between combatants and noncombatants will blur, and that civilian service providers such as those supplying power, cloud storage and internet connectivity could increasingly be seen as military targets (CSIS, 2025a). That is CSIS's forecast, and it is contested ground in law and policy. I cite it as a warning about dependency, not as a statement of law.

Overdependence. CSIS says militaries "will need to incorporate technology without depending on it," and that "a force multiplier is a high-priority target for an opponent" (CSIS, 2025a).

Five fronts

I organize the lessons into five fronts, and add two more that cut across all of them: command and people.

Front	What public analysis describes	The same feature on your network
Trenches	Defenders who can dig in with effective counter-drone measures hold an advantage; cover and concealment matter	Depth: segmentation, identity at every line, a small trust zone

Front	What public analysis describes	The same feature on your network
Drones	Cheap, numerous, flexible; economics favor the cheap	Automated scanning, credential stuffing, floods, bots; cheap automated controls in reply
Electronic warfare	Jamming and spoofing of signals; EW is the norm	Spoofed identities, time, names and voices; verify out of band; keep a second source
Sensors	Near-transparency; assume you are seen	Exposed surface; edge devices; your own telemetry; deception
Supply lines	Logistics in constant peril; commercial dependencies	Suppliers, cloud, platforms; offline copies; manual fallbacks
Command	Decentralized units; fast learning cycles	Decision rights; out-of-band comms; short lessons-learned loops
People	Endurance, integrated technology without overdependence	Staffing, rotation, skill; AI as a helper, not a crutch

Where the comparison breaks

I owe you the limits.

A network is not terrain. You cannot dig a trench in an IP range. And you can restore a server from a backup, which is not something a lost position allows.

Your adversaries are not armies. Most of the pressure on a mid-size organization comes from criminals, opportunists and automated tools. Some comes from more capable actors. The lens helps with the shape of the contest. It does not tell you who is on the other end.

Statistics do not transfer. A figure from a battlefield study tells you nothing about your firewall. That is why I use no battlefield statistics at all. My numbers come from breach and incident research, and I cite them to their sources.

Do not mistake analogy for instruction. This paper does not tell you to take any action against any adversary. Offensive action by private organizations raises legal and safety problems, and it is not what this paper recommends.

Finally, a caution about the analogy itself. The point of the lens is not drama. The point is that long, cheap, constant pressure is a different problem from a single dramatic attack, and it needs a different kind of plan.

Now the fronts, one at a time.

Analysis: five fronts and two cross-cutting concerns

The next seven parts take the fronts in turn. Each part follows the same pattern: what public sources describe, what it means for your network, what to do, and what to measure.

Part I: Trenches. Depth beats a hard shell

What public analysis describes. CSIS says that "defenders who can dig in with effective counter-drone measures will have a significant advantage, and those who must cross open land will be at a significant disadvantage" (CSIS, 2025a). It adds that cover and concealment are of the utmost importance (CSIS, 2025a).

Two ideas there. Depth. And making the attacker cross open ground.

What it means for you. For thirty years, many networks were built like a shell. Hard outside. Soft inside. One firewall and a VPN. Get past the wall and you can walk anywhere.

NIST's zero trust guidance describes the problem with a picture from an airport. All passengers pass a security checkpoint, then mill about the terminal, "and all the individuals are considered trusted." That boarding area is what NIST calls the "implicit trust zone." NIST then makes the point that matters: "the implicit trust zone must be as small as possible" for the policy decision point to be as specific as it can be (NIST SP 800-207, 2020).

Shrink the zone where everyone is trusted. That is the whole idea.

NIST defines zero trust as "an evolving set of cybersecurity paradigms that move defenses from static, network-based perimeters to focus on users, assets, and resources." It assumes "no implicit trust granted to assets or user accounts based solely on their physical or network location" (NIST SP 800-207, 2020).

Its tenets read like a field order for a defender who expects to be penetrated:

- All communication is secured regardless of network location. Network location alone does not imply trust.
- Access to individual resources is granted on a per-session basis, with the least privileges needed.
- Access is determined by dynamic policy, including client identity, application and the requesting asset, and may include behavioral and environmental attributes.
- The enterprise monitors and measures the integrity and security posture of all owned and associated assets. No asset is inherently trusted.
- Authentication and authorization are dynamic and strictly enforced before access is allowed.

- The enterprise collects as much information as possible about the current state of assets, network infrastructure and communications, and uses it to improve its security posture (NIST SP 800-207, 2020).

NIST is honest about the limits: these tenets are "the ideal goal," and not all may be fully implemented in their purest form (NIST SP 800-207, 2020).

Why depth matters in a war of attrition

An attacker with persistence will eventually get a foothold. A phished account. An exposed edge device. A stolen credential. Verizon notes that attackers are "increasingly blending in with normal operations by using the same access paths as legitimate users," such as desktop-sharing tools and virtual private networks (Verizon, 2026). It adds that threat actors seem to be dialing back reliance on traditional tools such as Cobalt Strike as defenders get better at detecting and blocking them (Verizon, 2026).

That is measure and countermeasure in your own logs. The contest moved. Your design has to assume the first line will be crossed.

NIST's cyber resiliency guidance names the design moves. Among its techniques:

- **Coordinated protection.** "Require a threat event to overcome multiple safeguards," increasing the cost to the adversary and the likelihood of detection.
- **Segmentation.** Contain adversary activity to the enclave, segment or facility where it has established a presence, limiting where malware can propagate.
- **Realignment.** Minimize connections between mission-critical and non-critical services, so that a failure in the latter does not reach the former.
- **Privilege restriction.** Make the adversary invest more time and effort obtaining credentials, and curtail what stolen credentials can do.
- **Diversity.** Use heterogeneity to minimize common-mode failures and make the adversary build tools for more than one target type (NIST SP 800-160 Vol. 2 Rev. 1, 2021).

The same document is candid about costs. It notes that "diversity and segmentation can each make analytic monitoring and contextual awareness more difficult," because diverse systems need tools that can handle the variety, and segmentation can limit visibility (NIST SP 800-160 Vol. 2 Rev. 1, 2021).

Depth is not free. Each line you dig has to be manned, watched and maintained. A trench line nobody patrols is a ditch.

The trench map

Here is a simple way to lay it out. I call these lines. They are my own organizing device, drawn from the NIST and CISA material above. They are not a standard.

Line	Question it answers	Typical controls	What to watch
0. The edge	What does the internet touch?	Inventory of internet-facing assets; patching of edge devices; removal of unused services; management interfaces off the internet	Exposure count; time to patch known-exploited flaws
1. Identity	Who or what is asking?	Phishing-resistant multifactor authentication; per-session access; least privilege; service-account inventory	Privileged accounts; dormant accounts; unusual sign-ins
2. Segments	How far can one foothold travel?	Network and application segmentation; separate management network; restricted east-west traffic	Cross-segment flows; new connections between systems that never talk
3. Crown assets	What cannot be lost?	Data classification; stronger controls and logging around critical systems; separate admin paths	Access to crown data; unusual bulk reads
4. Recovery	How do we come back?	Tested, isolated backups; rebuild runbooks; alternate communications	Restore time actually achieved in rehearsal

Four of those five lines do not stop the attacker. They slow, contain, expose and survive. That is the point. In attrition, nothing is impenetrable. The goal is to make every step cost more than it is worth, and to see it happening.

A maturity ladder you can borrow

CISA's Zero Trust Maturity Model is written for federal agencies, but its structure helps anyone. It organizes zero trust into five pillars: Identity, Devices, Networks, Applications and Workloads, and Data. It adds three cross-cutting capabilities: Visibility and Analytics, Automation and Orchestration, and Governance. It describes maturity in four stages: Traditional, Initial, Advanced and Optimal. Each pillar can progress at its own pace (CISA ZTMM, 2023).

In the Networks pillar, the model's progression runs from large perimeter or macro-segmentation, through isolation of critical workloads and expanded ingress and egress micro-perimeters, toward micro-segmentation around application profiles (CISA ZTMM, 2023).

For a mid-size organization, treat "Optimal" as a direction, not a deadline. Move each pillar one stage at a time. The stage you are in matters less than whether you know it, and whether you can show movement from quarter to quarter.

What to do

1. **Draw your real lines.** Take the five lines above and write, for each, what you have today. Be blunt. Mark each as strong, partial or absent.

2. **Shrink the implicit trust zone.** Start with the most valuable segment. Move administrative access onto a separate path. Require phishing-resistant authentication for administrators and remote access first.
3. **Segment before you buy.** Segmentation that exists on a diagram does not count. Test it. Try to reach a crown system from an ordinary workstation, with permission, and write down what happens.
4. **Pay the monitoring cost.** For every line you add, decide what telemetry crosses it and who looks at it.
5. **Keep it boring.** Simple designs that people understand survive staff turnover. Elaborate ones decay.

What to measure

- Number of segments that contain crown assets, and number of rules allowing traffic into them.
- Share of administrator and remote-access accounts using phishing-resistant authentication.
- Number of systems in the implicit trust zone: those a single compromised workstation can reach.
- Time to restore a crown system from backup, in a rehearsal.

Do not compare your numbers with a survey median. Compare them with your own last quarter.

Part II: Drones. Cheap mass against your attention

What public analysis describes. The economics come first. CSIS puts them in one line: “If a $500 drone can destroy a multimillion-dollar tank, so, too, can a USV swarm destroy a fleet of ships” (CSIS, 2025a). That is a statement about cost asymmetry, not a measurement of how often it happens. CSIS also says “counter-drone solutions will be decisive on the future battlefield” (CSIS, 2025a), and describes the most marked change as cheap, flexible and highly maneuverable ISR drones (CSIS, 2025a).

Cheap. Many. Flexible. The answer to it is not one exquisite shield. It is a layered, cheap, repeatable defense, and a way to keep from running out of it.

What it means for you. Your drones are not aircraft. They are software. Automated scanning for exposed services. Credential stuffing against login pages. Bot traffic. Floods. Commodity phishing kits sold as a service. ENISA describes Phishing-as-a-Service as “automation that paves the way for attackers regardless of their experience” (ENISA, 2025). The same logic as the drone: low cost, low skill, high volume.

The 2026 Verizon DBIR gives a sense of the scale on the flooding side. Its year-in-review timeline records a botnet of 300,000 internet-of-things hosts launching a record 29.7 Tbps DDoS attack, nearly doubling previous peaks (Verizon, 2026). Meanwhile, the median attack size has stayed between 4.2 and 6 Gbps, and half of all attacks last under nine minutes (Verizon, 2026). Both things are true. The peaks grow. The routine stays small and cheap.

For an organization your size, the peak is a vendor problem. The routine is yours.

The cost exchange

Here is the exchange in plain terms. The left column is the attacker's cheap move. The right column is the defender's cheap answer. This is my summary, built on the sources cited in this part. It is not a measured result.

Cheap move against you	What it costs you if unanswered	Cheap answer
Automated login attempts using stolen credentials	Account takeover; investigation time	Multifactor authentication on externally exposed applications and remote access; lockout and rate limits
Mass phishing and pretexting	Analyst time per report; a successful click	Phishing-resistant authentication; reporting button; verification rules for payment and identity requests
Scans for old, exposed services	One unpatched edge device is a way in	Inventory of the edge; automated patching; remove what you do not use
Short flood bursts, repeated	Outage minutes; staff pulled off other work	Upstream DDoS protection; a rehearsed runbook; clear thresholds for escalation
AI bot traffic hitting sites and APIs	Bandwidth, content exposure, noise	Rate limits; bot management; robots rules; monitoring

Notice what is in the right column. No miracle. Authentication, patching, inventory, capacity and a plan.

Verizon's mitigation guidance for exploited vulnerabilities and stolen credentials lines up with the table: require MFA for externally exposed applications and for remote network access, and perform automated operating system and application patch management (Verizon, 2026).

Plan for the tail, not the average

Verizon gives numbers worth building a runbook around. For the repeatedly attacked DDoS victims in its sample, Verizon reports a median attack duration of 24 minutes. At the higher end of the distribution, it puts duration at around 88 minutes at the 90th percentile and 101 minutes at the 95th (Verizon, 2026).

So design for roughly two hours. Ask three questions.

1. Which customer-facing or revenue-critical services would be unavailable for two hours, and what would that cost?
2. Who decides when to switch to the upstream mitigation or the backup path, and what do they need to know?

3. What does the rest of the team do during a flood? Verizon's own question is the right one: "What would be the impact to your business if your business was affected?" (Verizon, 2026).

One caution, and it is my judgment, not a finding. Treat any flood as a possible distraction. While your eyes are on the loud problem, check the quiet ones. Make sure someone is assigned to do exactly that.

Counter-drone for the network: four layers

Absorb. Put capacity between the flood and your service. For most mid-size organizations, that means buying protection from an upstream provider rather than building it. Ask for written answers on how it works, how fast it engages, and what it costs when attacks run long.

Filter. Rate limits, bot management, geo and reputation rules where they make sense, and strong authentication on every login surface. Verizon notes that defenders have to "maintain our footing and use collaboration and partnerships" against growing attacker capability (Verizon, 2026). Sharing with peers and providers counts as a layer.

Automate. Cheap and repeatable. Patch automation. Configuration baselines. Alert enrichment. IBM found that security teams extensively using AI and automation shortened breach times by 65 days and lowered average costs by USD 1.93 million compared with those that did not. Only 36% of breached organizations said they used these tools extensively across the security lifecycle (IBM and Ponemon Institute, 2026). That is an association in a benchmark study. It is not proof of what a tool will do for you. But the direction is clear: volume answered by automation.

Intercept, with a human on the trigger. Automated response can contain a compromised account or isolate a host faster than a person can. It can also cause an outage faster than any attacker. Start every automated action in recommend-only mode. Widen authority as evidence supports it. Keep a clear off switch and a named owner.

CSIS gives the right caution from the battlefield side: when both sides have AI-enabled systems, "the incentive will lean heavily toward deferring as much as possible to the AI's capability," and "for now, that surely will lead to mistakes" (CSIS, 2025a). Replace "targeting" with "triage" and the warning still holds. Do not let your people turn into a stamp of approval.

The next turn of the cycle

CSIS offers a forecast, flagged as a forecast. It says sophisticated adversaries will probably find ways to combine AI and cyberattacks, with "offense likely outstripping defense at first," and that AI agents will be able to find vulnerabilities and exploit them "without phoning home and raising alarms" (CSIS, 2025a). Treat that as a planning assumption, not as a fact.

What follows from it? Shorter patch windows on the edge. More weight on detection of behavior over indicators. More automation on your side, built on the same cheap controls.

What to do

1. **Write the cost-exchange table for your own organization.** Five rows. Their move, your cost, your cheap answer. Fill in the missing right-hand cells and fund the gaps.
2. **Put MFA on every externally exposed login and every remote access path.** Administrators and remote access first.
3. **Automate patching on the edge.** Set a target time for known-exploited vulnerabilities on internet-facing systems, and track it.
4. **Buy absorption, do not build it.** Get upstream flood protection in writing, and run a rehearsal.
5. **Run the two-hour drill.** Simulate a two-hour outage of one customer-facing service and note what breaks.
6. **Start automation in recommend-only mode,** and review overrides weekly.

What to measure

- Median time to remediate known-exploited vulnerabilities on internet-facing systems (your baseline, not a survey median).
- Share of external login surfaces protected by multifactor authentication.
- Mean time from flood detection to mitigation engagement, in rehearsal.
- Analyst hours spent per week on repetitive triage, and the share handled by automation with human review.

Part III: Electronic warfare. When the signal lies

What public analysis describes. Jamming blocks a signal. Spoofing sends a false one. A note from three EU member states to the Council of the EU defines them plainly: jamming is deliberate radio interference "when information about an aircraft location, altitude, and time is not received," and spoofing is deliberate interference in which wrong signals are sent "and aircraft location, altitude, and time are displayed incorrectly" (Council of the EU, 2025).

CSIS calls the pervasiveness of EW one of the most dominant features of the modern battlefield, and a "temporary and reversible way" to degrade satellite navigation and communications. It says EW will be the norm, and that militaries will place "a premium on operating effectively in degraded environments" (CSIS, 2025b).

The effects reach civilians. IATA data, cited in a joint release with the European Union Aviation Safety Agency (EASA), says GPS signal loss events increased 220% between 2021 and 2024 (EASA and IATA, 2025). EASA's Flight Standards Director put the strategic shift this way: "We are no longer just containing GNSS interference — we must build resilience" (EASA and IATA, 2025). The Finnish Transport and Communications Agency reported that disruptions in the Gulf of Finland had "already caused near misses," that signal disruptions "may cause unexpected malfunctions, for example in vessels' autopilot

functions," and that spoofing of the Automatic Identification System, where incorrect data is fed in, "has also become more frequent" (Traficom, 2025).

And note what it says next: "alongside AIS, other systems are also used to verify data on the location and movement of ships" (Traficom, 2025). A second source.

What it means for you. This is the part of the battlefield that travels furthest into your network. Not the jammer. The principle. When the thing a machine trusts can be falsified, every decision built on it is exposed.

The Council note adds the point that matters for your clocks. Satellite navigation systems provide positioning, navigation and timing. The timing services "also serve for time synchronization of telecommunication networks, and, thus, are vital to enable seamless communication, synchronize financial transactions, stabilize power grids, etc." (Council of the EU, 2025).

Your time is a signal

Most security teams do not think about time as a dependency. They should.

NIST's Foundational Positioning, Navigation and Timing (PNT) profile tells organizations to identify all software, applications and systems that depend on PNT data, including those that rely on distributed time. Its examples of dependent applications include "test and measurement tools, kernels, databases, logging software, cryptography/certificate management, and other software that rely on synchronized clocks or positioning information" (NIST IR 8323r1, 2023).

Read that again with your own stack in mind. Logging. Certificates. Databases. If your time source is wrong, your logs are out of order, your certificates may fail validation, and your incident timeline is fiction.

The profile's advice on testing is concrete. For systems with redundant or complementary time sources, validate by "removing the primary time source and confirming that the time accuracy and precision" meet pre-defined requirements for the time server and downstream applications (NIST IR 8323r1, 2023). It also says to prioritize "maintaining essential functions despite system disruption or manipulation" (NIST IR 8323r1, 2023).

Test it. Pull the primary time source in a controlled window, with change approval, and see what breaks.

Other signals that can lie

Time is the least visible. The rest are more familiar.

Identity. A login that is valid, from a device that looks right, by someone who is not who they say. Verizon found credential abuse is pervasive: considering all instances of credential abuse at any point in a breach, it sits at 39% (Verizon, 2026).

Voice and text. Verizon draws a line between phishing, which it describes as an essentially asynchronous social action, and pretexting, which "intrinsically involves a synchronous component": someone on the other end of a call or thread, trying to convince a person to do something they should not. It warns that the countermeasures and training for the two are distinct (Verizon, 2026). Help-desk impersonation is a live example. IBM reports that social engineering such as impersonating help desk staff was used in 13% of attacks and led to average breach costs of USD 5.23 million, and that voice and SMS phishing, used in 17% of attacks, led to the highest average costs among attack vectors at USD 5.29 million (IBM and Ponemon Institute, 2026).

Synthetic media. CSIS says adversaries are already employing AI for deepfakes meant to sow doubt and confusion, and forecasts that the next iteration "could entail deepfake military orders" and realistic denial and deception operations designed to sow tactical chaos (CSIS, 2025a). It adds that, with adversarial AI generating deception at machine speeds, "trust in such information will be tested" (CSIS, 2025b). Your version is a deepfaked executive voice asking finance for an urgent transfer. That is a scenario, not a statistic. The controls are not exotic.

The second source

Dead reckoning, the theme of the first paper in this series, is the habit of navigating without a signal: last known position, heading, speed, time and a second source. Here is the network version.

Signal you trust	What can go wrong	Second source	Drill
Time	Drift or false time from a single source	At least two independent time sources; alert on divergence	Remove the primary source in a change window and check logs, certificates and authentication
Identity	Stolen or replayed credentials; impersonated help-desk requests	Device posture; a second factor that resists phishing; call-back to a known number for sensitive requests	Test the help-desk verification procedure with an authorized, scoped exercise
Voice and video	Synthetic or impersonated speakers	Out-of-band verification through a known channel; pre-agreed words for urgent requests	Run a payment-approval drill in which the "boss" is not real
Name and routing data	Altered answers from systems you rely on	Cross-check against an independent resolver or source; log and alert on changes	Compare answers from two sources on critical names during a review
Alerts and logs	A tool that goes silent, or a log source that stops	Heartbeat checks; a second detection path for crown assets	Silence one sensor and see how long it takes anyone to notice

I will not describe how to carry out any of these attacks. The point of the table is the right-hand columns.

Degraded operations

CSIS says the future will require using technology "without depending on it." It gives the example of a force that depends entirely on satellite navigation, which could find itself "toothless" if the signal goes dark, and notes that one academy is teaching navigation by the stars as a coping mechanism. It says that if a drone swarm is taken down by electronic warfare, the unit "must be able to fight on" (CSIS, 2025a).

Your version: what do we do when the tool is down? Not the SIEM is slow. The SIEM is gone. Not the VPN is flaky. The VPN is the problem.

CSIS also describes a technical adaptation: fiber-optic tethers, which it calls "impervious to jamming" (CSIS, 2025a) and which "eliminate reliance on wireless signals" (CSIS, 2025b). The defender's analog is simple. Keep a wired, separate, out-of-band path to manage your most important systems. If the path you use to fix the network is the network you are fixing, you have one point of failure.

What to do

1. **List your signals.** Time, identity, names, voice, alerts. For each, name the second source.
2. **Run two independent time sources,** and alert when they disagree. Then test removing the primary one.
3. **Set verification rules** for payment, credential reset and access requests. Use a callback to a number you already hold. Make the rule easy to follow and impossible to skip, even for the most senior person.
4. **Rehearse degraded operations.** Once a quarter, run one critical process with a tool unavailable. Use the old checklist. Write down what was missing.
5. **Build an out-of-band management path** for your most critical systems and keep it separate from daily use.
6. **Treat synthetic media as a normal risk.** Train the people who move money and reset accounts, and give them the authority to say no.

What to measure

- Number of independent time sources per critical system, and time to detect drift between them.
- Share of sensitive requests verified through an out-of-band channel.
- Time for the team to notice a silenced log source in a drill.
- Time to complete a critical business process in degraded mode, against normal mode.

Part IV: Sensors. Assume you are being watched

What public analysis describes. CSIS says commercial sensors have changed the battlefield. "All militaries must adapt to a world where movements, emissions, and signatures are constantly monitored." It adds that forces, "especially those at fixed sites and massed in central locations, must assume that they will be seen and their movements and emissions detected." Its prescription is "renewed emphasis on operational security, deception tactics, and electromagnetic spectrum discipline," with exercises that "simulate conditions where adversaries possess near-real-time ISR capabilities" (CSIS, 2025b).

A second CSIS chapter makes the human point. "Information is cheap. Processing it is expensive, and sense-making is exquisite." It also warns that rival services can use video data and a person's "digital dust" to reveal an identity that was meant to stay hidden (CSIS, 2025c).

Two lessons. Your signature is visible. And your own sensors only help if you can make sense of what they tell you.

What it means for you. Start from the adversary's side of the glass. MITRE's ATT&CK framework opens its list of tactics with Reconnaissance: "The adversary is trying to gather information they can use to plan future operations." The tactic covers adversaries "actively or passively gathering information that can be used to support targeting," and the information "may include details of the victim organization, infrastructure, or staff/personnel" (MITRE ATT&CK, TA0043). Its technique list includes active scanning of IP blocks and vulnerabilities, gathering host, identity and network information, and searching open websites and technical databases.

You are scanned all day. Most of it is noise. Some of it is a survey.

Your signature

Your signature is everything an outsider can learn about you without breaking in. Think in five layers.

Layer	What an outsider can see	The question to ask
Network	Address ranges, open services, certificate names, old test systems	Does every internet-facing service have an owner and a reason?
Software	Product names and versions in banners, headers and file paths	Does the outside need to know which product and version we run?
People	Names, roles, email formats, job postings, public social media	What does our public staff information say about who holds the keys?
Code and cloud	Public repositories, storage buckets, files left shared	What did we publish by accident, and who checks?
Behavior	Working hours, response times, vendor relationships	What does our rhythm tell a patient observer?

This is not about hiding. Visibility is how business gets done. The goal is to know your signature and make deliberate choices about it, the way a unit chooses where to be seen.

CSIS frames this for militaries as emissions and signature discipline (CSIS, 2025b). Your civilian equivalent is attack surface management. Inventory what is exposed. Remove what is not needed. Patch what must stay. Then look at it again next month, because it will have changed.

Count what you can see, then cut

The most valuable signature exercise costs almost nothing. Ask your team to produce a list of everything on the internet that is yours, using the same public sources an outsider would. Compare it with your asset register. The gap between the two lists is the work.

Joint guidance on network edge devices, released by CISA, NSA and partner agencies in February 2025, points the same way. NSA lists seven mitigation strategies, starting with "know the edge," and including disabling unneeded features and ports and securing management interfaces (NSA, 2025; CISA, 2025). An NSA expert explains why the edge matters: "if left unsecured, even unskilled malicious cyber actors have an easier time finding and exploiting vulnerabilities in their software or configurations" (NSA, 2025).

Deception, with limits

NIST's cyber resiliency guidance includes a Deception technique: "Mislead, confuse, hide critical assets from, or expose covertly tainted assets to the adversary." It says deception can lead the adversary to waste effort and reveal tactics, techniques and procedures. It also says deception can complicate analytic monitoring and contextual awareness, and that these techniques "come at a cost to some other cyber resiliency objectives" (NIST SP 800-160 Vol. 2 Rev. 1, 2021).

Remember that when a vendor sells you a deception product. The idea has a long record in adversarial fields. NIST itself notes that Deception, Dynamic Positioning and Unpredictability are cyber adaptations of concepts from adversarial disciplines such as medicine, military and sports (NIST SP 800-160 Vol. 2 Rev. 1, 2021). Used well, a few decoy credentials, files or services that no legitimate user would ever touch give you a near-zero-noise alarm. Used badly, they are one more system to maintain and one more source of confusion.

My advice is modest. Start with a small number of decoys in places that matter. Make sure each one raises an alert that a human will see. Do not build a maze you cannot monitor.

Your own sensors: the problem of sense-making

Now the other direction. What do you see?

IBM's 2026 study found that the mean time to identify and contain a breach was 247 days (IBM and Ponemon Institute, 2026). That is a sense-making number. The evidence was there. Someone had to find it, read it and decide.

CSIS's line applies exactly: information is cheap, processing it is expensive (CSIS, 2025c). Most mid-size organizations are not short of logs. They are short of attention. Three failure patterns recur:

1. **Everything collected, nothing asked.** Terabytes of logs with no question attached.
2. **Alerts without owners.** Detections that fire into a queue nobody is accountable for.
3. **Sensors without a heartbeat.** A source that quietly stops, and nobody knows.

NIST's incident response guidance (SP 800-61r3) is now written to sit inside the CSF 2.0 functions: Govern, Identify, Protect, Detect, Respond and Recover (NIST SP 800-61r3, 2025; NIST CSF 2.0, 2024). That helps. It puts detection beside governance and recovery in one loop, not in a silo.

A small-sensor philosophy

Build detection from decisions, not from data.

- Start with the five or six decisions you must make fast in an incident. Isolate a host. Disable an account. Take a service offline. Notify a customer or regulator. Call counsel and law enforcement.
- For each decision, name the signals you need to make it with confidence.
- Collect and retain those signals first. Add more only when a question demands it.
- For each signal, assign an owner, a response time and a heartbeat check.

Fewer sensors, better understood, beat a sprawl nobody can read.

Keep your own secrets from the wire

CSIS's phrase "digital dust" belongs on a poster in your office. Staff leave trails. Contractors leave trails. Old test systems leave trails. Cloud sharing links live forever unless someone ends them. A few steps pay off quickly:

- Review public repositories, shared drives and storage for exposed secrets and files.
- Set expiry on sharing links and temporary access.
- Rotate any credential that has ever appeared in a ticket, chat or document.
- Give staff clear guidance on what not to post about internal systems.

What to do

1. **Make the outside-in list.** Everything public that belongs to you. Reconcile with your asset register. Fix the gaps.
2. **Pick your signature rules.** Decide what must be public, what can be reduced, and who approves exceptions.
3. **Define your six decisions** and the signals behind each one. Retire collection that serves no decision.

4. **Give every alert an owner and a clock.**
5. **Add heartbeats** to every critical log source, and test that silence raises an alert.
6. **Start small on decoys,** with legal and privacy sign-off, and only where a human will see the alarm.
7. **Exercise with a watcher in mind.** Run one tabletop a year that assumes the adversary has seen your public footprint for months.

What to measure

- Number of internet-facing assets without a named owner.
- Gap between the outside-in list and your asset register.
- Median time from alert to first human action.
- Share of critical log sources with a working heartbeat check.
- Share of alerts that lead to a decision, versus alerts closed as noise.

Part V: Supply lines. The rear is part of the front

What public analysis describes. CSIS says supplying front lines "will be more challenging—and likely deadlier—than ever," and that modern forces "need to anticipate that only a fraction of supplies will get through." Forces will therefore "seek to minimize deliveries to the front lines" and adopt technologies that increase self-sufficiency, such as on-site production of parts (CSIS, 2025a). It also says that as commercial providers take on more of the work, the line between combatants and noncombatants blurs: providers of power, cloud storage and internet connectivity could increasingly be seen as legitimate targets (CSIS, 2025a). Read that as a statement about shared infrastructure. In your world, the shared infrastructure is the cloud and the carrier.

Keep your own parallels in view, and keep them modest. Supply lines are long. They run through other people. They are watched, and they break.

What it means for you. Your supply lines are your vendors, your software dependencies, your cloud providers, your connectivity, your managed service providers, your payment processors and your power. Most of it lives outside your walls. You rely on it. You cannot patch it.

The numbers on dependence

Verizon's 2026 DBIR reports that breaches with third-party involvement increased by 60% from the prior year's dataset, reaching 48% of total breaches (Verizon, 2026). It describes root causes in many cloud-based third-party incidents that "boil down to insecure authentication (absence of MFA, improper credential rotation) or lack of least privilege enforcement for users or service accounts" (Verizon, 2026). In a survival analysis of third-party cloud exposures, only 23% of organizations had fully remediated missing or improperly secured multifactor authentication, though half of findings were resolved within a month (Verizon, 2026).

IBM's 2026 report ranks supply chain compromise as the second most common initial attack vector, and the second slowest to resolve, taking 258 days to identify and contain (IBM and Ponemon Institute, 2026). ENISA observes that attackers abuse cyber dependencies, creating a "ripple effect across the supply chain" (ENISA, 2025).

Read those numbers as direction, not precision. Each study defines "third party" and counts breaches differently. The direction is consistent: the more you rely on others, the more their weaknesses become yours.

The ordinary mistakes

Most supply line failures are dull.

- **No list.** You cannot defend dependencies you have not named.
- **Trust by contract.** A security questionnaire, filed once, and never looked at again.
- **Flat access.** A vendor account that can reach more than the vendor's job needs.
- **One route.** A single connectivity provider, a single cloud region, a single identity provider, a single payment rail.
- **No exit.** No plan for the day a supplier is breached, suspended or simply gone.

NIST's CSF 2.0 turns this into a category of its own: Cybersecurity Supply Chain Risk Management (GV.SC) under the Govern function. Its outcomes include that "suppliers are known and prioritized by criticality," that requirements are "integrated into contracts and other types of agreements," that supplier risks are "understood, recorded, prioritized, assessed, responded to, and monitored over the course of the relationship," that relevant suppliers are "included in incident planning, response, and recovery activities," and that plans cover what happens "after the conclusion of a partnership or service agreement" (NIST CSF 2.0, 2024).

That list is the best brief I know. Map it onto your own contracts and see which lines are blank.

Triage the supply line

You cannot treat every supplier alike. Sort them.

Tier	Who sits here	What you do
1. Cannot operate without	Identity provider, core cloud platform, primary connectivity, payment processing, the one software package that runs the business	Written security requirements; incident contact; right to be told; a tested fallback plan; an owner at senior level
2. Painful to lose	Collaboration tools, CRM, HR systems, specialist SaaS	Standard security terms; access limited to what the job needs; a data export you have tested
3. Replaceable	Everything else	Basic review; do not give broad access

For tier 1, ask hard questions in writing. How would you tell us about an incident, and how fast? What do you do if your own supplier is breached? Where does our data live? How do we leave?

Keep the rear from burning

CSIS offers a principle you can borrow from logistics: self-sufficiency (CSIS, 2025a). For networks, this means the ability to operate through a failure upstream, for a while.

- **A second route for what matters.** A second connectivity path. A second DNS provider. A backup identity path for administrators. Not for everything.
- **Local copies of what you need.** Data exports of the systems that run the business, kept where you control them, in formats you can read without the vendor.
- **Manual procedures,** printed and tested, for critical operations.
- **Limits on blast radius.** Treat vendor connections as untrusted. Give each its own segment, its own account and its own logging.

NIST's cyber resiliency guidance adds a warning that fits here. Redundancy-supporting approaches such as backup, surplus capacity and replication "are not sufficient to protect against" an advanced persistent threat. A threat actor might choose backup servers as "optimum locations to implant malware" if they are not sufficiently protected, and remote backup servers built with the same architecture as the primary may share its weakness (NIST SP 800-160 Vol. 2 Rev. 1, 2021). A second copy that shares the first copy's weaknesses is the same line drawn twice. That is why diversity appears in the same list.

Software dependencies

Treat software like any other supply: know what is in it. For critical applications, keep a software bill of materials, track which versions you run, and know who to ask when a component is announced as vulnerable. For the edge, the joint guidance lists "procure secure-by-design devices" among its seven strategies (NSA, 2025). You cannot always do that. When you cannot, the compensating control is to limit and monitor what the product can reach.

Exercise the break

NIST's guidance on incident response says incidents "occur frequently and cause far more damage," and recovery "often takes weeks or months." It also urges that lessons be shared as soon as they are identified, "not delayed until after recovery concludes" (NIST SP 800-61r3, 2025). For supply lines, that means exercising the day a tier 1 supplier fails or is breached. Who calls whom? What do we switch off? What do we tell customers? How long can we last?

Run it once a year. Invite the supplier if they will come.

What to do

1. **Build the supplier list.** Name every tier 1 and tier 2 dependency. Record owner, data held, access given and exit path.
2. **Tier them.** Apply different rules to each tier.
3. **Review vendor access.** Remove accounts and permissions that are not needed. Put multifactor authentication and logging on the rest.
4. **Close the dullest gaps first.** A single route, no exit plan, no incident contact.
5. **Test one fallback.** Pick the highest-impact tier 1 supplier and rehearse running without it.
6. **Put incident duties in contracts** at renewal. Notification timelines, cooperation, data return.
7. **Share lessons early.** Hold a short review after any supplier incident, before the dust settles.

What to measure

- Share of tier 1 suppliers with a named internal owner, a tested fallback and a documented incident contact.
- Number of vendor accounts with access beyond their stated purpose.
- Time to run a critical process in fallback mode, in rehearsal.
- Share of tier 1 and tier 2 contracts that carry incident notification terms.

Part VI: Command. Decide faster than the grind

What public analysis describes. CSIS says the future is "shifting toward smaller, highly mobile, adaptable units, where field commanders are empowered to make decisions about cover, concealment, and tactics while minimizing their communications signature" (CSIS, 2025a). It says fast cycles of adaptation mean fronts may evolve at different paces, "necessitating central nodes to facilitate sharing lessons learned," and that "units will need resilient mesh networks to ensure continuous communication even if multiple nodes go dark" (CSIS, 2025a). It reports a "six week learning cycle" attributed to a RUSI analyst, in which measures and countermeasures follow each other in weeks, not years (CSIS, 2025a). Another chapter says drone developers pushed innovation cycles to "weeks rather than months or years" (CSIS, 2025b).

Three ideas: decisions pushed to the edge, lessons pulled to the center, and communications that survive losing a node.

What it means for you. Command is the cross-cutting concern that decides whether all five fronts work together. It is not a rank. It is how decisions are made, how fast, by whom, and what happens when the person who normally decides is unreachable.

The decision clock

Compare two clocks.

IBM's 2026 study puts the mean time to identify and contain a breach at 247 days (IBM and Ponemon Institute, 2026). Verizon's 2026 DBIR puts the median time to fully patch known-exploited vulnerabilities at 43 days, up from 32 (Verizon, 2026). Attack bursts, as shown in Part II, run in minutes and hours.

An organization whose decisions run on a slower clock than the pressure on it loses ground even when it is doing the right things. The target is not speed at any cost. The target is that no routine decision waits for a meeting.

Pre-decided authority

In an incident you do not want to discover who can approve what. Decide it in advance.

- **Pre-authorized actions.** A short list of actions that on-call staff may take without asking: disable an account, isolate a host, block an address range, revoke a token. Write down the conditions. Review them after use.
- **Escalation triggers.** Clear lines for when a decision moves up: a crown system, customer data, a regulator notice, a public statement, a payment.
- **Delegation if unreachable.** Every decision-maker has a named deputy with the same authority. The deputy has the numbers, the access, and the standing to act.
- **Intent, not scripts.** State what must be protected and what may be sacrificed. Let those closest to the problem choose the method.

That last point is my own recommendation, drawn from the shape of the CSIS description. It is not a quotation from any doctrine. But the logic is the same as CSIS's: distant, slow, centralized decisions fail under pressure, and local authority must be bounded by clear limits (CSIS, 2025a).

The cost of delegation is mistakes. Accept some. Review them without punishing the people who acted in good faith. Otherwise nobody will act next time.

Lessons to the center, fast

CSIS says a more widespread battlefield may see fronts evolve at different paces, "necessitating central nodes to facilitate sharing lessons learned" (CSIS, 2025a). NIST SP 800-61r3 says to share lessons "as soon as they are identified, not delayed until after recovery concludes" (NIST SP 800-61r3, 2025).

For you that means:

- **A running log** kept during every incident and every near miss, with a short note on what worked and what did not.
- **A weekly fifteen-minute review** of the log. One owner. Output: at most three changes.

- **A change channel** where findings turn into tickets, with an owner and a date.
- **Outside sources.** Join an information-sharing community in your sector. Verizon's own advice for the growing capability of attackers is to "maintain our footing and use collaboration and partnerships" (Verizon, 2026).

Keep the loop short. A lesson that waits for the quarterly meeting is a lesson that gets forgotten.

Communications that survive a lost node

CSIS's mesh-network idea has a plain analog: crisis communications that do not depend on the thing that failed (CSIS, 2025a). If email is down, how do you reach each other? If chat is down? If your identity provider is down and nobody can log in?

Build a short communications plan:

1. **A primary channel,** the one you normally use.
2. **An out-of-band channel** that does not depend on your identity provider or primary network. Agree in advance which one, and who has the credentials.
3. **A phone tree** on paper, kept current, with deputies.
4. **A rule** for confirming that a message is real before acting on it, including voice and video, as in Part III.

Test it quarterly. Ask the question: who did not get the message?

Governance without ceremony

NIST's CSF 2.0 places Govern at the center of its six functions, alongside Identify, Protect, Detect, Respond and Recover (NIST CSF 2.0, 2024). That framing helps in practice. Governance is not paperwork. It is the set of decisions leadership has made, in advance, about what to protect, what to tolerate, and who decides.

For a mid-size organization, a one-page "risk appetite and decision rights" sheet may be the most useful governance document you can write. Name your crown assets. Name the maximum downtime you can accept for each. Name who may approve a deviation. Revisit it every six months.

What to do

1. **Write the pre-authorized action list.** Five to ten actions. Conditions. Owner. Review date.
2. **Name deputies** for every decision-maker, and give them access and authority.
3. **Draw the escalation triggers** on one page.
4. **Start the lessons log** and the weekly fifteen-minute review.
5. **Build and test the out-of-band communications plan.**

6. **Write the one-page decision rights sheet** and have leadership sign it.

What to measure

- Time from detection to first containment action, in incidents and exercises.
- Share of incident decisions made within pre-authorized limits.
- Time from a lesson identified to the change deployed.
- Share of the response team reached through the out-of-band channel within ten minutes, in a drill.

Part VII: People. Endurance is the strategy

What public analysis describes. CSIS notes that new drone units "require a vastly different skill set than traditional infantry" and that recruitment and training programs had to be intensified to build them (CSIS, 2025a). That sentence is generic. It says something every security leader knows: when the nature of the work changes, the people have to change with it, and it takes time.

CSIS also warns of leaning on technology as a crutch: "Using technology as a crutch happens today," and that militaries "must be ready to lose those tools and keep fighting" (CSIS, 2025a). The same chapter says the human tendency to defer to machine recommendations is a hazard in itself (CSIS, 2025a).

What it means for you. People are the second cross-cutting concern, and in a war of attrition they are the scarcest resource. Tools can be bought. Experience cannot.

ISC2's 2024 workforce study found 67% of respondents reported a staffing shortage and 90% reported one or more skills gaps (ISC2, 2024). Verizon's analysis of small and medium-sized organizations found that most ransomware victims, among cases where size was known, were small or mid-size (Verizon, 2026). The ones with the smallest teams face the same cheap pressure as the ones with the largest.

I do not cite burnout or turnover statistics here. The sources I opened for this paper do not measure them. I will say only what any security manager can see on their own team: sustained pressure, with no end date, wears people down.

Design the team for endurance

A short fight can be won with heroics. A long grind cannot. The practical rules are not glamorous.

Rotate. Put on-call duty on a rota with real recovery time after a heavy shift. Do not let the same two people carry every incident.

Cross-train. For each critical function, name at least two people who can do it. Test it by having the second person do it, with the first person watching, once a quarter.

Write it down. Runbooks for the ten things that go wrong most often, and the five that go wrong worst. Plain language. Tested by someone who did not write them.

Protect attention. Cut alerts that never lead to action (see Part IV). Automate repetitive triage where you can, with human review (Part II). IBM found that extensive use of AI and automation in security was associated with a shorter breach lifecycle and lower costs (IBM and Ponemon Institute, 2026). Whatever you automate, keep a person accountable.

Keep a bench. An incident response retainer, a managed detection provider, or a mutual-aid arrangement with a peer organization. Agree terms before you need them. Know who answers the phone at 3 a.m.

Train in the open. Exercises should include non-technical staff. Finance, legal, communications and executive assistants are part of the line. CSIS's guidance on exercises is for militaries, but the principle carries over: simulate conditions where the adversary has good information (CSIS, 2025b). Assume they know your org chart.

Skills that matter now

The mix of skills changes as the fronts shift. A few that I would grow in a mid-size team:

- **Identity and access.** The craft of making access narrow and short-lived.
- **Cloud and third-party risk.** Reading a provider's responsibility model and finding where it leaves you exposed.
- **Detection engineering.** Turning a decision into a signal (Part IV).
- **Resilience engineering.** Backups, restores, failover and degraded operations (Parts III and V).
- **Communication.** Plain, calm writing and speaking under pressure. Underrated.

You will not hire all of them. Train, contract and partner.

Humans and machines

CSIS's cautionary note on AI is about judgment: when both sides use AI, the incentive is to defer to it, and for now that will lead to mistakes (CSIS, 2025a). Applied to security operations, it is a rule worth writing down:

- AI recommends. A named human decides, for anything that affects customers, access or money.
- Each automated action has a log, an owner and an off switch.
- People review a sample of automated decisions every week and write down what they find.
- Nobody is judged by how often they agree with the tool.

Morale is operational

I will keep this short. Say thank you. Name what went well in every post-incident review. Make sure people can take leave. Make sure the person who raised the alarm is thanked, not blamed. Those are cheap. They also decide whether your best people are still there in a year.

What to do

1. **Build the rota.** Include recovery time. Name deputies.
2. **Map single points of human failure.** For every critical function, name two people.
3. **Write and test ten runbooks.**
4. **Sign a bench.** Retainer, partner or mutual-aid agreement, with a tested contact path.
5. **Run a cross-functional exercise** with finance, legal, communications and executives.
6. **Write the human-in-the-loop rule** for AI and automation, and review a sample every week.

What to measure

- Number of critical functions with fewer than two trained people.
- Share of runbooks tested by someone other than their author in the last six months.
- Distribution of on-call load across the team.
- Time to reach your outside bench in a test call.

Part VIII: Three scenarios

These three scenarios are **hypothetical**. They are not reports of real incidents, real organizations or real results. They contain no statistics. They exist to show how the fronts interact, and to give your team something to rehearse.

Each scenario is a mid-size organization, roughly a few hundred staff, with a small security team and several outside providers. Use them as prompts for a tabletop exercise. Replace the details with your own.

Scenario one: The long week

A regional services company. Monday to Friday.

Monday. The edge. A vendor publishes a notice about a flaw in a remote access appliance. It is on the list of known-exploited vulnerabilities. The company runs that appliance. The patch window is scheduled for the following weekend because of a customer deadline.

Tuesday. Drones. A flood hits the customer portal for twenty minutes, stops, then returns an hour later. The on-call engineer spends the afternoon on the upstream mitigation. Meanwhile, a wave of phishing messages reaches finance and the help desk.

Wednesday. Sensors. The scanning traffic against the appliance rises. The log source for the appliance has been quiet for days. Nobody noticed, because nobody was asked to watch it.

Thursday. Command. A help-desk call, convincingly polite, asks for a password reset for a senior manager who is traveling. The help-desk agent is under pressure and has no verification rule for resets.

What good looks like.

- The edge appliance is on the list of tier-1 internet-facing assets. The known-exploited flaw triggers a pre-authorized emergency patch outside the normal window. A named owner decides in hours, not days.
- The flood runbook is rehearsed. The on-call engineer engages upstream protection by the book, and a second person checks the quiet systems while the loud one is being handled.
- A heartbeat check on the appliance's logs fires on Tuesday, not after the fact.
- The help-desk rule requires a call-back to a known number for any reset of a privileged or traveling executive's account. The agent follows the rule, and nobody criticizes the delay.
- By Friday the team has reviewed what happened, changed three things, and rested.

Questions for your tabletop. Who can approve an emergency patch outside the window? What do we turn off if the appliance cannot be patched in time? Who is watching the quiet log source?

Scenario two: The quiet clock

A professional services firm. A bad afternoon.

Situation. A time source used by several internal systems begins to drift. The drift is small at first. Log timestamps no longer line up between systems. A certificate validation error appears on one internal service, then another. The help desk begins to receive reports of failed sign-ins.

At the same time, someone calls the finance team using a voice that sounds like the managing partner. It asks for an urgent payment to a new account, citing a confidential deal. The caller says not to discuss it by email.

Pressure points by front.

- **Electronic warfare, in the sense of Part III.** Time and voice are both signals. Both can be wrong. The two events may be unrelated, or one may be covering for the other. The team does not know.
- **Sensors.** Logs with inconsistent time make it hard to build a timeline. Analysts lose confidence in the data.

- **Command.** Who decides whether to take an authentication service offline to investigate? Who decides whether the payment is real?
- **People.** The finance clerk is junior. The caller is senior.

What good looks like.

- Two independent time sources are configured, and an alert fires when they disagree. The team switches to the second source under a runbook, rather than debating which clock is right.
- The finance team has a rule: new payee, urgent request, any channel, requires out-of-band verification through a known number, and a second approver. The clerk follows it. The managing partner, called back on a number from the directory, knows nothing about it.
- Incident notes record the time source and the drift, so the timeline can be rebuilt later.
- Leadership has told the team, in advance, that following the rule is correct even when the person asking is the most senior in the firm.

Questions for your tabletop. Which of our systems would fail first if time were wrong? Who can stop a payment at 4:55 p.m. on a Friday? Have we tested this rule against someone who sounds exactly like the boss?

Scenario three: The vendor goes dark

A distribution business. A supplier fails.

Situation. A cloud service that handles the company's orders is unavailable. The provider's first notice is vague. Hours pass. Later, the provider states that it is investigating a security incident and that customer data may be affected. Staff cannot take orders. The managed service provider that administers part of the network is also affected, and its support line is overloaded.

Pressure points by front.

- **Supply lines.** One provider carries a critical process. There is no second route.
- **Trenches.** The provider's connection into the company's systems uses an account with broad permissions.
- **Command.** The incident has no owner inside the company. Customers are asking questions. The sales team wants to promise dates.
- **People.** Staff have been working through the night. The one person who understands the integration is on leave.

What good looks like.

- The supplier is on the tier-1 list. The company holds a recent export of order data in a readable format, and a manual procedure for taking orders by phone and spreadsheet for a limited time. Staff have practiced it once.

- The vendor connection runs through its own segment with its own account, restricted to what the integration needs. The company disables the connection on its own authority while the vendor investigates.
- A named incident owner decides what to tell customers and when. A short holding statement goes out early and is updated at set times.
- The contract with the provider contains incident notification duties, which the company invokes. The company asks the provider written questions and logs the answers.
- A second person has been trained on the integration. The rota gives the first person leave.

Questions for your tabletop. If this supplier were gone for a week, what would we do? Who may disable the connection? What would we say to customers in the first two hours?

What the scenarios share

None of these events is exotic. Each is ordinary pressure applied from several directions. In every one, the organization that does well has done unglamorous work in advance: a list, a rule, a rehearsal, a named owner. The organization that does badly usually has the same tools. It has not decided what to do.

Run one scenario a quarter. Change the details. Write down what you find.

Recommendations

Here is the plan.

It is not glamorous. It is a campaign built around depth, cheap layers, second sources, a small signature, a rear that can burn, and decisions that do not wait for permission. The seven parts above each end with their own actions. This section puts them in order.

Add capability only when the controls and the evidence are in place. Timelines depend on your team size, your tooling and your risk appetite. The phases below are a sequence first and a schedule second.

The seven moves

#	Move	Front it answers	First proof that it is working
1	**Map the ground.** Inventory the edge, crown assets and dependencies.	Sensors; Supply lines	The outside-in list matches your asset register
2	**Dig in.** Segment, shrink the implicit trust zone, and move administrators onto a separate path.	Trenches	A test from an ordinary workstation cannot reach a crown system
3	**Close the cheap doors.** MFA on exposed logins, automated patching on the edge, upstream flood protection.	Drones	Known-exploited flaws on the edge are fixed within your target time
4	**Keep a second source.** Two time sources, out-of-band verification, a heartbeat on every critical log.	Electronic warfare	A drill with the primary source removed shows no surprise
5	**Reduce your signature.** Shrink what the outside sees, build detection from decisions, and place a few decoys with legal sign-off.	Sensors	Every alert has an owner and a clock
6	**Plan for the rear to burn.** Tier your suppliers, keep exports and manual procedures, and rehearse the break.	Supply lines	One tier 1 fallback has been run end to end
7	**Decentralize the decisions.** Write down who may act, keep an out-of-band communications path, and share lessons within days.	Command; People	A pre-authorized action was used and reviewed

THE TAKEAWAY

Map first. Dig in second. Close the cheap doors before you buy anything exotic. Keep a second source for every signal you trust. Plan for the rear to burn. Decide before you have to.

What the battlefield teaches the plan

Each lesson from The modern battlefield maps to a part of the plan. Use this as a check on your own program.

Battlefield lesson	What it teaches	Where it lands in the plan
Depth beats a hard shell	Assume the first line is crossed; make every step cost more	Segmentation; per-session access; recovery rehearsals
Cheap mass versus exquisite systems	Answer volume with cheap, repeatable, automated layers	MFA; edge patching; upstream flood protection; automation with human review
Signals can be jammed and spoofed	Verify out of band; keep a second source	Time sources; call-back rules; heartbeat checks
You are being watched	Know your signature; make sense of your own sensors	Outside-in list; decision-led detection; decoys with limits
The rear area is not safe	Suppliers and platforms are terrain	Tiered supplier list; exports; manual fallbacks; contract terms
Decentralize decisions, protect communications	Pre-authorize; keep a channel that does not depend on what you defend	Decision rights; deputies; out-of-band channel; lessons loop
Endurance decides	Staff for year two, not week two	Rotas; cross-training; runbooks; a bench

And a check to run each quarter. Five questions:

1. **Where are the lines?** Is your trench map current, with strong, partial and absent marked honestly?
2. **What can the outside see?** When did you last compare the outside-in list with your register?
3. **What is the second source?** For time, identity and every critical signal, is there an independent check?
4. **What if the rear burns?** When did you last rehearse a tier 1 supplier failing?
5. **Who may act?** Does everyone on the rota know what they can do without asking?

The first 90 days

Days 1 to 30: Map and baseline

- Assemble the outside-in list of everything internet-facing that belongs to you. Reconcile it with the asset register and assign an owner to every item.
- Draw the trench map with five lines. Mark each strong, partial or absent.
- List your top signals (time, identity, names, voice, alerts) and note the second source for each, or the gap.

- Write down today's baseline: time to patch known-exploited flaws on the edge, share of exposed logins with MFA, time to restore a crown system, time from alert to first human action.
- Build the supplier list and tier it.
- Write the pre-authorized action list and name deputies.

Days 31 to 60: Close the cheap doors

- Patch the edge. Remove services nobody can justify. Put management interfaces behind a separate path.
- Require MFA on every external login and remote access path, starting with administrators.
- Confirm upstream flood protection in writing. Run the two-hour drill.
- Add heartbeat checks to critical log sources.
- Set verification rules for payments, credential resets and access requests. Brief the people who handle them.
- Stand up the out-of-band communications path and test it once.

Days 61 to 90: Rehearse and decide

- Run one scenario from Part VIII as a tabletop.
- Run a controlled test of removing the primary time source in a change window.
- Test the first fallback for your most important tier 1 supplier.
- Start the lessons log and the weekly review.
- Write the one-page decision rights sheet and have leadership sign it.
- Re-measure the baseline. Report the change to leadership, including what did not move.

The first 12 months

Quarter	Focus	What you deliver
Q1 (days 1 to 90)	Map, close, rehearse	Everything in the 90-day plan
Q2	Dig deeper	Segment your most valuable systems; separate administrator access; extend phishing-resistant authentication to all staff who touch crown assets
Q3	See and decide	Decision-led detection for the six key decisions; first decoys; automation in recommend-only mode, then limited authority; second tabletop with finance, legal and communications
Q4	Survive and adapt	A full tier 1 supplier failure exercise; contract terms updated at renewal; re-run the self-assessment; set next year's targets from your own results

Throughout the year:

- **Every widening of authority is a decision,** made by a named owner, documented and reversible.

- **Every incident and near miss feeds the lessons log.**
- **Every quarter, report to leadership** on the metrics and on what went wrong.
- **Every year, re-run the self-assessment** below.

Self-assessment checklist

Use this checklist with your security, IT and leadership teams. Answer honestly. A “no” is not a failure. It is a work item.

Score each item: 0 = not in place, 1 = partly in place, 2 = fully in place and evidenced. The levels at the end are my rough guide, not a formal standard.

Trenches

☐ The trench map exists and is reviewed at least twice a year.

☐ Administrators use a separate access path with phishing-resistant authentication.

☐ Crown systems sit in segments that an ordinary workstation cannot reach, and this has been tested.

☐ A restore of a crown system from isolated backup has been rehearsed in the last year.

Drones

☐ MFA protects every externally exposed login and every remote access path.

☐ Known-exploited vulnerabilities on internet-facing systems have a target patch time, and it is measured.

☐ Upstream flood protection is in place, with a written runbook and a rehearsal.

☐ Automated actions run under a human-in-the-loop rule, with logs and an off switch.

Electronic warfare

☐ Critical systems use at least two independent time sources, and disagreement raises an alert.

☐ Requests to move money, reset credentials or grant access follow an out-of-band verification rule.

☐ A critical process has been run in degraded mode in the last year.

☐ An out-of-band management path exists for the most critical systems.

Sensors

☐ An outside-in list of internet-facing assets exists and has been reconciled with the asset register.

☐ Every alert has an owner and a response time.

☐ Every critical log source has a heartbeat check.

☐ Public repositories, shared links and storage have been reviewed for exposed secrets and files in the last six months.

Supply lines

☐ A supplier list exists, with tiers, owners, data held and access granted.

☐ Vendor accounts are limited to what each integration needs, with MFA and logging.

☐ Data exports for tier 1 and tier 2 systems are kept where you control them, in formats you can read.

☐ A tier 1 supplier failure has been exercised in the last year.

☐ Tier 1 contracts contain incident notification and cooperation terms.

Command

☐ A pre-authorized action list exists, with conditions and review dates.

☐ Every decision-maker has a named deputy with access and authority.

☐ A lessons log is kept, with a weekly review and an owner.

☐ An out-of-band communications path exists, and it has been tested in the last quarter.

People

☐ The on-call rota includes recovery time, and load is shared.

☐ Every critical function has at least two trained people.

☐ Runbooks exist for the ten most likely and five worst failures, and someone other than the author has tested them.

☐ An outside bench (retainer, partner or mutual aid) exists, with a tested contact path.

☐ Exercises include finance, legal, communications and executives.

Reading your score

There are 30 items, for a maximum of 60 points.

- **0–19: Foundational.** Map the ground, close the cheap doors, and fix single points of failure before anything else.
- **20–39: Developing.** The basics are partly in place. Prioritize second sources, supplier fallbacks and decision rights.
- **40–60: Established.** Deepen segmentation, automate with care, and keep rehearsing.

Whatever your score, the next step is the same: pick the three lowest items that matter most to your risk, assign owners and dates, and re-score in a quarter.

A starter scorecard

Report these to leadership each quarter. Compare against your own baseline. Do not compare with a survey median.

Measure	Front	Direction
Time to patch known-exploited flaws on the edge	Drones	Down
Share of external logins with MFA	Drones	Up
Systems in the implicit trust zone	Trenches	Down
Time to restore a crown system, in rehearsal	Trenches	Down
Independent time sources per critical system	Electronic warfare	Up
Internet-facing assets without an owner	Sensors	Down
Median time from alert to first human action	Sensors	Down
Tier 1 suppliers with a tested fallback	Supply lines	Up
Time from detection to first containment action	Command	Down
Critical functions with fewer than two trained people	People	Down

Conclusion

The sources agree on direction.

Exploitation of known flaws is still a leading way in. Credentials still get stolen and used. Floods and bots arrive every day. Suppliers carry more of your risk each year. Breaches that run long cost more. Teams are short of people and skills (Verizon, 2026; IBM and Ponemon Institute, 2026; ISC2, 2024).

The public analysis of the modern battlefield points the same way. Depth. Cheap mass. Spoofed and jammed signals. Constant observation. Supply lines that are never safe. Fast cycles of measure and countermeasure (CSIS, 2025a; CSIS, 2025b; CSIS, 2025c). Your organization is not at a front line. But it works in the same electromagnetic and informational weather, and it faces the same economics: cheap pressure against costly defense.

You will not win that by matching them effort for effort. You win it the way resilient institutions do.

Dig in, so the first breach is not the last line. Spread out, so one failure does not take everything. Keep a second source, so a false signal does not steer you. Know what the outside can see, and make sense of what your own sensors tell you. Keep the rear from burning, and know how to fight when it does. Push decisions to the people closest to the problem, and learn faster than the grind wears you down.

Above all, keep going. This is a long contest, and the organizations that do well in it are the ones that are still doing the boring work in year three.

Infinitum Corporation helps organizations take these steps in a way that fits their size, systems and risk appetite. I make no promise about the outcome any organization will achieve, and every figure in this paper belongs to the source cited.

Don’t take my word for it. Read the sources, then decide.

This is the second paper in a series. The first is *Dead Reckoning: AI for Security Operations in a Jammed, Spoofed, Watched World*. The next is *Break It Before They Do: Authorized Hacking for Organizations Under Siege*.

Let’s stay engaged. Visit https://www.theinfinitumcorporation.com. Dialogue is key.

About Infinitum Corporation

Infinitum Corporation is a technology and security consulting firm headquartered in Washington, DC, delivering practical, integrated security solutions.

Our work spans cybersecurity consulting, network architecture and defense, vulnerability assessment and ethical hacking, IT security, AI for security operations, strategic risk assessment and emerging defense technology advisory. Our ethical hacking work is always authorized, scoped and approved in writing, and performed for defense.

William Aaron Turner is Founder and President.

Website	https://www.theinfinitumcorporation.com
Email	info@theinfinitumcorporation.com
Telegram	https://t.me/infinitumcorporation
X	https://x.com/infinitumceo
Address	1629 K Street NW, Suite 300, Washington, DC

References

1. CISA (Cybersecurity and Infrastructure Security Agency). (2023, April). *Zero Trust Maturity Model, Version 2.0.* https://www.cisa.gov/zero-trust-maturity-model
2. CISA, NSA, and partner agencies. (2025, February 4). *Guidance and Strategies to Protect Network Edge Devices.* https://www.cisa.gov/resources-tools/resources/guidance-and-strategies-protect-network-edge-devices
3. Council of the European Union (General Secretariat). (2025, May 21). *Call for common actions in response to Global Satellite Navigation Systems (GNSS) jamming and spoofing threats* (note 9188/25, from three member states; used here only for its general definitions and its description of timing services). https://data.consilium.europa.eu/doc/document/ST-9188-2025-INIT/en/pdf
4. CSIS (Pusztaszeri, A., & Harding, E.). (2025, September 16). *Technological Evolution on the Battlefield,* in the CSIS report *War and the Modern Battlefield* (subtitle omitted to keep this paper party-neutral). Center for Strategic and International Studies. https://www.csis.org/analysis/chapter-9-technological-evolution-battlefield (cited as CSIS, 2025a)
5. CSIS (Bingen, K. A.). (2025, September 16). *Extending the Battlespace to Space,* in the CSIS report *War and the Modern Battlefield* (subtitle omitted to keep this paper party-neutral). Center for Strategic and International Studies. https://www.csis.org/analysis/chapter-8-extending-battlespace-space (cited as CSIS, 2025b)
6. CSIS (Harding, E.). (2025, September 16). *Intelligence in a Transparent World,* in the CSIS report *War and the Modern Battlefield* (subtitle omitted to keep this paper party-neutral). Center for Strategic and International Studies. https://www.csis.org/analysis/chapter-7-intelligence-transparent-world (cited as CSIS, 2025c)
7. EASA and IATA. (2025, June 18). *EASA and IATA outline comprehensive plan to mitigate GNSS interference risks.* https://www.easa.europa.eu/en/newsroom-and-events/press-releases/easa-and-iata-outline-comprehensive-plan-mitigate-gnss
8. ENISA. (2025, October 1). *EU consistently targeted by diverse yet convergent threat groups* (ENISA Threat Landscape 2025 press release). https://www.enisa.europa.eu/news/etl-2025-eu-consistently-targeted-by-diverse-yet-convergent-threat-groups
9. IBM and Ponemon Institute. (2026). *Cost of a Data Breach Report 2026.* https://assets.ibm.com/adobe/assets/urn:aaid:aem:21111142-1251-4369-86fb-57b82f5bb108/original/as/Cost%20of%20a%20Data%20Breach%20Report%202026.pdf
10. ISC2. (2024, October 31). *2024 ISC2 Cybersecurity Workforce Study.* https://www.isc2.org/Insights/2024/10/ISC2-2024-Cybersecurity-Workforce-Study
11. MITRE. *ATT&CK, Reconnaissance (TA0043).* https://attack.mitre.org/tactics/TA0043/
12. NIST. (2024, February 26). *The NIST Cybersecurity Framework (CSF) 2.0* (NIST CSWP 29). https://doi.org/10.6028/NIST.CSWP.29
13. NIST (Rose, S., Borchert, O., Mitchell, S., & Connelly, S.). (2020, August). *Zero Trust Architecture* (SP 800-207). https://csrc.nist.gov/pubs/sp/800/207/final
14. NIST (Ross, R., Pillitteri, V., Graubart, R., Bodeau, D., & McQuaid, R.). (2021, December). *Developing Cyber-Resilient Systems: A Systems Security Engineering Approach* (SP 800-160 Vol. 2 Rev. 1). https://csrc.nist.gov/pubs/sp/800/160/v2/r1/final
15. NIST (Nelson, A., Rekhi, S., Souppaya, M., & Scarfone, K.). (2025, April). *Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile* (SP 800-61 Rev. 3). https://csrc.nist.gov/pubs/sp/800/61/r3/final

16. NIST (Bartock, M., et al.). (2023, January). *Foundational PNT Profile: Applying the Cybersecurity Framework for the Responsible Use of Positioning, Navigation, and Timing (PNT) Services* (NIST IR 8323 Rev. 1). https://csrc.nist.gov/pubs/ir/8323/r1/final

17. NSA. (2025, February 4). *Joint Publications Focus on Mitigation Strategies for Edge Devices* (press release). https://www.nsa.gov/Press-Room/Press-Releases-Statements/Press-Release-View/article/4052657/joint-publications-focus-on-mitigation-strategies-for-edge-devices/

18. Traficom (Finnish Transport and Communications Agency). (2025, June 13). *Finland and Estonia warn vessels in the Gulf of Finland of an increase in GNSS disruptions.* https://traficom.fi/en/news/finland-and-estonia-warn-vessels-gulf-finland-increase-gnss-disruptions

19. U.S. Army Center for Army Lessons Learned. (2025, July). *Understanding Irregular Warfare* (No. 25-897), quoting JP 1 Vol 1, *Joint Warfighting* (2023, August 27). https://www.army.mil/article/286976/understanding_irregular_warfare

20. Verizon. (2026). *2026 Data Breach Investigations Report.* https://www.verizon.com/business/resources/Te26/reports/2026-dbir-data-breach-investigations-report.pdf

Note on in-text tags. Short tags such as (Verizon, 2026), (IBM and Ponemon Institute, 2026), (ISC2, 2024), (ENISA, 2025), (CSIS, 2025a), (CSIS, 2025b), (CSIS, 2025c), (Council of the EU, 2025), (Traficom, 2025), (EASA and IATA, 2025), (NIST SP 800-207, 2020), (NIST SP 800-160 Vol. 2 Rev. 1, 2021), (NIST SP 800-61r3, 2025), (NIST IR 8323r1, 2023), (NIST CSF 2.0, 2024), (CISA ZTMM, 2023), (CISA, 2025), (NSA, 2025), (MITRE ATT&CK, TA0043) and (U.S. Army CALL, 2025) refer to the entries above. Sources were opened and read between October 25 and 26, 2026. Where a source is quoted, the words are the source's own. Where a number is cited, it belongs to that source and describes that source's dataset.

Note on neutrality. This paper draws general lessons about technology and conflict from public sources. It takes no side and makes no claim about any party. Where a source attributes events or reports figures about specific parties, those attributions and figures are left out here. Titles of the CSIS report and chapters are shortened to keep this paper party-neutral. The URLs lead to the full originals.

Glossary

ATT&CK. MITRE's knowledge base of adversary tactics and techniques based on real-world observations, used to map detections and find coverage gaps.

Attrition. A contest won by endurance and cost exchange, not by a single decisive event.

Blast radius. How far the damage from one compromised account, device or supplier can spread.

CSF 2.0. The NIST Cybersecurity Framework version 2.0, organized around six functions: Govern, Identify, Protect, Detect, Respond and Recover.

Crown assets. The systems and data whose loss would most damage the organization.

DDoS (distributed denial of service). An attack that floods a service with traffic from many sources so that legitimate users cannot reach it.

Deception (defensive). Placing decoy assets, credentials or data inside your own environment so that intruders who interact with them reveal themselves. Always with legal sign-off.

Edge device. A firewall, router, VPN gateway or other system that sits between your internal network and the internet.

Electronic warfare (EW). The use of the electromagnetic spectrum to jam, spoof or otherwise disrupt signals, and the defense against that.

GNSS. Global navigation satellite systems, such as GPS, which provide location and timing.

Implicit trust zone. An area in which every entity is trusted because of where it sits, not because of what it has proved. NIST says it should be as small as possible.

Irregular warfare. Joint doctrine describes it as "indirect, non-attributable, or asymmetric" competition. Used in this paper as an analytic lens only.

ISR. Intelligence, surveillance and reconnaissance.

Jamming. Deliberate interference that blocks a radio signal.

KEV. CISA's Known Exploited Vulnerabilities catalog: flaws with evidence of active exploitation.

MFA (multifactor authentication). Requiring more than a password to sign in. Phishing-resistant forms resist being relayed to an attacker.

Out-of-band. Using a separate channel, such as a known phone number, to verify a request or to manage a system, so that one failure does not take out both.

PNT. Positioning, navigation and timing.

Segmentation. Dividing a network into zones so that a compromise in one does not spread freely to others.

Spoofing. Deliberately sending false signals or data so that a system displays or accepts something incorrect.

Tabletop exercise. A discussion-based rehearsal in which a team walks through a scenario and decides what it would do.

Zero trust. In NIST's words, an evolving set of cybersecurity paradigms that move defenses from static, network-based perimeters to a focus on users, assets and resources.